



# PRECURSOR ANALYSIS REPORT: HAVEX MALWARE IN A U.S. MANUFACTURING FACILITY 2014

Cybersecurity for the Operational Technology  
Environment (CyOTE)

30 JUNE 2022



U.S. DEPARTMENT OF  
**ENERGY**

Office of  
Cybersecurity, Energy Security,  
and Emergency Response

This document was prepared by Idaho National Laboratory (INL) under an agreement with and funded by the U.S. Department of Energy.

INL is a U.S. Department of Energy National Laboratory operated by Battelle Energy Alliance, LLC

## TABLE OF CONTENTS

|                                                                                           |           |
|-------------------------------------------------------------------------------------------|-----------|
| <b>1. EXECUTIVE SUMMARY .....</b>                                                         | <b>2</b>  |
| <b>2. INTRODUCTION .....</b>                                                              | <b>3</b>  |
| 2.1. APPLYING THE CYOTE METHODOLOGY .....                                                 | 3         |
| 2.2. BACKGROUND ON THE ATTACK .....                                                       | 5         |
| <b>3. OBSERVABLE AND TECHNIQUE ANALYSIS .....</b>                                         | <b>7</b>  |
| 3.1. SPEARPHISHING ATTACHMENT TECHNIQUE (T0865) FOR INITIAL ACCESS .....                  | 7         |
| 3.2. DRIVE-BY COMPROMISE TECHNIQUE (T0817) FOR INITIAL ACCESS .....                       | 8         |
| 3.3. SUPPLY CHAIN COMPROMISE TECHNIQUE (T0862) FOR INITIAL ACCESS .....                   | 9         |
| 3.4. USER EXECUTION TECHNIQUE (T0863) FOR EXECUTION .....                                 | 10        |
| 3.5. INDICATOR REMOVAL ON HOST TECHNIQUE (T0872) FOR EVASION .....                        | 11        |
| 3.6. REMOTE SYSTEM DISCOVERY TECHNIQUE (T0846) FOR DISCOVERY .....                        | 12        |
| 3.7. REMOTE SYSTEM INFORMATION DISCOVERY TECHNIQUE (T0888) FOR DISCOVERY .....            | 13        |
| 3.8. POINT AND TAG IDENTIFICATION TECHNIQUE (T0861) FOR COLLECTION .....                  | 14        |
| 3.9. AUTOMATED COLLECTION TECHNIQUE (T0802) FOR COLLECTION .....                          | 15        |
| 3.10. COMMONLY USED PORT TECHNIQUE (T0885) FOR COMMAND AND CONTROL .....                  | 16        |
| 3.11. STANDARD APPLICATION LAYER PROTOCOL TECHNIQUE (T0869) FOR COMMAND AND CONTROL ..... | 17        |
| 3.12. DENIAL OF SERVICE TECHNIQUE (T0814) FOR INHIBIT RESPONSE FUNCTION .....             | 18        |
| 3.13. THEFT OF OPERATIONAL INFORMATION TECHNIQUE (T0882) FOR IMPACT .....                 | 19        |
| 3.14. DENIAL OF CONTROL TECHNIQUE (T0813) FOR IMPACT .....                                | 20        |
| <b>APPENDIX A: OBSERVABLES LIBRARY .....</b>                                              | <b>21</b> |
| <b>APPENDIX B: ARTIFACTS LIBRARY .....</b>                                                | <b>25</b> |
| <b>APPENDIX C: OBSERVERS .....</b>                                                        | <b>35</b> |
| <b>REFERENCES .....</b>                                                                   | <b>36</b> |

## FIGURES

|                                           |          |
|-------------------------------------------|----------|
| <b>FIGURE 1. CYOTE METHODOLOGY .....</b>  | <b>3</b> |
| <b>FIGURE 2. INTRUSION TIMELINE .....</b> | <b>5</b> |

## TABLES

|                                                                      |          |
|----------------------------------------------------------------------|----------|
| <b>TABLE 1. TECHNIQUES USED IN THE HAVEX CASE STUDY .....</b>        | <b>6</b> |
| <b>TABLE 2. PRECURSOR ANALYSIS REPORT QUANTITATIVE SUMMARY .....</b> | <b>6</b> |

# PRECURSOR ANALYSIS: USE OF HAVEX AGAINST A U.S. MANUFACTURING FACILITY IN 2014

## 1. EXECUTIVE SUMMARY

The Use of Havex Against a U.S. Manufacturing Facility in 2014 precursor analysis report leverages publicly available information about the Havex remote access trojan (RAT) and catalogs anomalous observables for each technique employed in the attacks. This analysis is based upon the methodology of the Cybersecurity for the Operational Technology Environment (CyOTE) program.

Havex, also referred to as Backdoor.Oldrea, PEACEPIPE, and Fertger, was a modular RAT used in the Dragonfly 1.0 cyberespionage campaign conducted by a Russian state-sponsored adversary from 2013 to 2014. Havex was targeted against multiple sectors such as energy, manufacturing, pharmaceutical, and others throughout the campaign.

Among its reconnaissance capabilities, Havex could scan industrial environments for assets using Open Platform Communications (OPC), an interoperability protocol popular in operational technology (OT) environments. This capability to scan for OPC assets is unique, particularly since Havex is one of the earliest pieces of malware that could specifically scan for industrial protocols. OPC is an interoperability protocol in wide use among multiple industries, and malware like Havex could be used to steal operational information, which could also result in unforeseen reliability issues. Havex also scanned TCP/IP network ports commonly used in OT environments, demonstrating a targeted approach by the adversary.

This report will illustrate the deployment of Havex against a U.S.-based manufacturing facility using OPC during the Dragonfly 1.0 campaign.

Researchers and analysts identified 14 techniques utilized during the attack with a total of 48 observables using the MITRE ATT&CK® for Industrial Control Systems framework. The CyOTE program assesses observables accompanying techniques used prior to the triggering event to identify opportunities to detect malicious activity

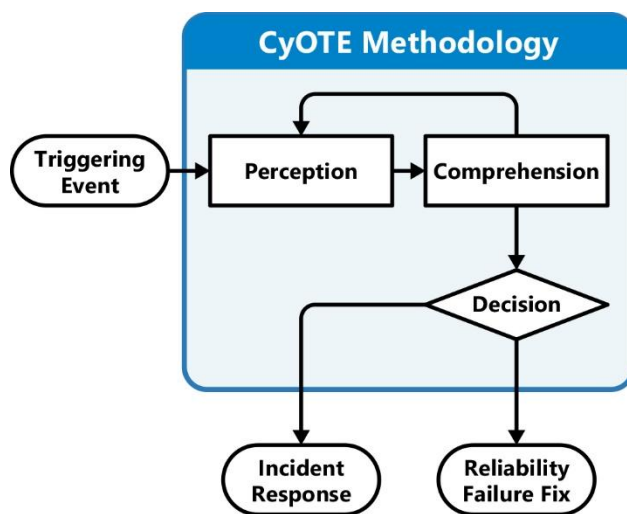
The information gathered in this report contributes to a library of observables tied to a repository of artifacts, data sources, and technique detection references to support the comprehension of indicators of attack. Asset owners and operators can use these products if they experience similar observables or to prepare for comparable scenarios.

## 2. INTRODUCTION

The [Cybersecurity for the Operational Technology Environment \(CyOTE\)](#) program developed capabilities for energy sector organizations to independently identify adversarial tactics and techniques within their operational technology (OT) environments. Led by Idaho National Laboratory (INL) under leadership of the Department of Energy (DOE) Office of Cybersecurity, Energy Security, and Emergency Response (CESER), CyOTE is a partnership with energy sector owners and operators whose goal is to tie the impacts of a cyber attack to anomalies in the OT environment to determine whether the anomalies have a malicious cyber cause.

### 2.1. APPLYING THE CYOTE METHODOLOGY

The CyOTE methodology, as shown in Figure 1. CyOTE Methodology, applies fundamental concepts of perception and comprehension to a universe of knowns and unknowns increasingly disaggregated into observables, anomalies, and triggering events. The program utilizes MITRE's ATT&CK® Framework for Industrial Control Systems (ICS) as a common lexicon to assess triggering events. By leveraging the CyOTE methodology with existing commercial monitoring capabilities and manual data collection, energy sector partners can understand relationships between multiple observables, which could represent a faint signal of an attack requiring investigation. CyOTE can assist organizations in prioritizing their OT environment visibility investments.



**Figure 1. CyOTE Methodology**

Historical case studies such as this one support continued learning through analysis of incidents that have impacted OT. This precursor analysis report is based on publicly available reports and provides examples of how key concepts in the CyOTE methodology appear in the real world, providing insights on how similar novel attacks could be detected earlier and therefore mitigated. The analysis enables OT personnel to independently identify observables associated with techniques known to be indicators of attack within OT environments. The identified observables highlight anomalous events for further investigation, which could enhance comprehension of malicious activity.

A timeline of events based on the CyOTE methodology portrays the attack-related observables associated with the case study's cyber attack. The timeline includes assessed dates, the triggering event, and comprehension of malicious activity by the organization. The point on this timeline when each technique appears is critical to the organization's ability to perceive and comprehend the associated malicious activity. Perception of techniques early in the timeline is critical, since halting those techniques will generally have greater potential to limit additional attack vectors using other techniques, defeat the cyber attack, and limit damage to operations.

Each technique has an assessed perceivability. Perceivability is a function of the number of observables and the potential for personnel to detect those observables. If a technique includes effects which personnel may detect, such as deletion or modification of system files or required user execution, then the technique would be more perceivable.

Differences in infrastructure and system configurations may present different challenges and opportunities for observable detection. For example, architecture-wide endpoint monitoring is likely to improve the perceivability of techniques which modify host files, such as the Data Destruction technique (T0809) for Inhibit Response Function and Theft of Operational Information technique (T0882) for Impact. Network monitoring and log analysis capabilities are likely to improve perceivability of techniques which create malicious network traffic, such as the Standard Application Layer Protocol technique (T0869) for Command and Control, External Remote Services technique (T0822) for Initial Access, and Connection Proxy technique (T0884) for Command and Control. Alternatively, enhancing the monitoring parameters of system files would increase the perceivability of techniques such as Data from Information Repositories technique (T0811) for Collection and the Service Stop technique (T0881) for Inhibit Response Function.

Comprehension can be further enhanced by technique artifacts created when adversaries employ certain attack techniques. The CyOTE program provides organizations with a [library of observables](#) reported in each historical case. The library can be used in conjunction with a repository of artifacts, data sources, and technique detection references to support the comprehension of indicators of attack.

## 2.2. BACKGROUND ON THE ATTACK

Havex was a modular remote access trojan (RAT) that enumerated and exfiltrated information about networked assets within industrial operational technology (OT) environments. Adversaries used Havex to conduct network reconnaissance against critical infrastructure sectors such as energy, pharmaceutical, and manufacturing from February 2013 to May 2014 in multiple countries.<sup>1</sup>

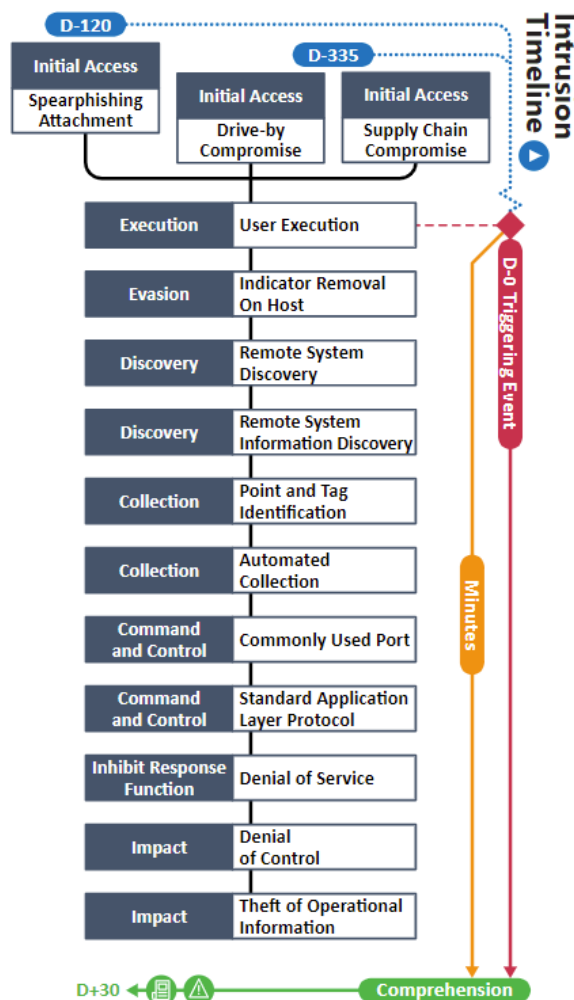
Havex is one of the earliest known pieces of malware designed to identify and exfiltrate information on industrial assets and protocols.<sup>2</sup> Havex is also noteworthy due to the increasingly stealthy infection vectors adversaries employed in their aggressive and broad-scoped campaign.<sup>3</sup> For example, the adversaries initially employed spearphishing emails (D-120) to deploy the malware but quickly transitioned to stealthier methods of initial access, including drive-by and supply chain compromises that lasted almost a full year (D-335).<sup>4</sup>

A timeline of adversarial techniques is shown in [Error! Reference source not found.](#). The timeline includes the estimated time prior to and after the triggering event. The timeline after the triggering event includes the assessed victim comprehension timeline.

Havex targeted Open Platform Communications (OPC), formerly known as Object Linking and Embedding (OLE) for Process Control, an industrial protocol in wide use in OT environments. OPC is known as a translation protocol prevalent in sectors that oversee OT assets.<sup>5</sup> OPC allows Windows-based software to communicate with diverse proprietary industrial protocols used by vendors, simplifying operation, monitoring, and data collection for the user.<sup>6</sup>

Once deployed, Havex would ascertain if there were any networked OPC assets within the local environment, as well as scan a number of TCP ports commonly used in industrial applications (M+10)<sup>a</sup> before exfiltrating the output of its scanning activities. This scanning activity can inadvertently cause OPC assets to malfunction, resulting in a temporary denial of service (D-0) or denial of control (D-0) scenario, as well as the theft of operational information (M+10).

This report focuses on Havex and its plugin that can enumerate OPC assets in a victim's environment, rather than the overarching cyberespionage campaign in which Havex was employed. Vendors and media outlets referred to this larger campaign as "Havex" but also as "Dragonfly 1.0". The "Dragonfly" moniker originates from Symantec, who dubbed the adversaries simultaneously using Havex and Karagany, another RAT, as Dragonfly in its reporting.<sup>7</sup> This study



**Figure 2. Intrusion Timeline**

<sup>a</sup> "M" corresponds to minutes prior to (M-) or after (M+) the triggering event; "D" events correspond to days prior to or afterward.

refers to the 2013-2014 campaign where the Havex RAT was observed in victim environments as the “Dragonfly 1.0 campaign” for clarity.

Analysis identified 14 techniques in a sequence and timeframe likely used by adversaries during this cyber attack. These attack techniques are defined according to MITRE’s ATT&CK® for ICS framework.

**Table 1. Techniques Used in the Havex Case Study**

| Initial Access                      | Execution                 | Persistence            | Privilege Escalation                  | Evasion                          | Discovery                                  | Lateral Movement                | Collection                            | Command and Control                        | Inhibit Response Function     | Impair Process Control       | Impact                                  |
|-------------------------------------|---------------------------|------------------------|---------------------------------------|----------------------------------|--------------------------------------------|---------------------------------|---------------------------------------|--------------------------------------------|-------------------------------|------------------------------|-----------------------------------------|
| Data Historian Compromise           | Change Operating Mode     | Modify Program         | Exploitation for Privilege Escalation | Change Operating Mode            | Network Connection Enumeration             | Default Credentials             | <b>Automated Collection</b>           | <b>Commonly Used Port</b>                  | Activate Firmware Update Mode | Brute Force I/O              | Damage to Property                      |
| <b>Drive-by Compromise</b>          | Command-Line Interface    | Module Firmware        | Hooking                               | Exploitation for Evasion         | Network Sniffing                           | Exploitation of Remote Services | Data from Information Repositories    | Connection Proxy                           | Alarm Suppression             | Modify Parameter             | <b>Denial of Control</b>                |
| Engineering Workstation Compromise  | Execution through API     | Project File Infection |                                       | <b>Indicator Removal on Host</b> | <b>Remote System Discovery</b>             | Lateral Tool Transfer           | Detect Operating Mode                 | <b>Standard Application Layer Protocol</b> | Block Command Message         | Module Firmware              | Denial of View                          |
| Exploit Public-Facing Application   | Graphical User Interface  | System Firmware        |                                       | Masquerading                     | <b>Remote System Information Discovery</b> | Program Download                | I/O Image                             |                                            | Block Reporting Message       | Spoof Reporting Message      | Loss of Availability                    |
| Exploitation of Remote Services     | Hooking                   | Valid Accounts         |                                       | Rootkit                          | Wireless Sniffing                          | Remote Services                 | Man in the Middle                     |                                            | Block Serial COM              | Unauthorized Command Message | Loss of Control                         |
| External Remote Services            | Modify Controller Tasking |                        |                                       | Spoof Reporting Message          |                                            | Valid Accounts                  | Monitor Process State                 |                                            | Data Destruction              |                              | Loss of Productivity and Revenue        |
| Internet Accessible Device          | Native API                |                        |                                       |                                  |                                            |                                 | <b>Point &amp; Tag Identification</b> |                                            | <b>Denial of Service</b>      |                              | Loss of Protection                      |
| Remote Services                     | Scripting                 |                        |                                       |                                  |                                            |                                 | Program Upload                        |                                            | Device Restart/Shutdown       |                              | Loss of Safety                          |
| Replication Through Removable Media | <b>User Execution</b>     |                        |                                       |                                  |                                            |                                 | Screen Capture                        |                                            | Manipulate I/O Image          |                              | Loss of View                            |
| Rogue Master                        |                           |                        |                                       |                                  |                                            |                                 | Wireless Sniffing                     |                                            | Modify Alarm Settings         |                              | Manipulation of Control                 |
| <b>Spearphishing Attachment</b>     |                           |                        |                                       |                                  |                                            |                                 |                                       |                                            | Rootkit                       |                              | Manipulation of View                    |
| <b>Supply Chain Compromise</b>      |                           |                        |                                       |                                  |                                            |                                 |                                       |                                            | Service Stop                  |                              | <b>Theft of Operational Information</b> |
| Wireless Compromise                 |                           |                        |                                       |                                  |                                            |                                 |                                       |                                            | System Firmware               |                              |                                         |

**Table 2. Precursor Analysis Report Quantitative Summary**

| Precursor Analysis Report Quantitative Summary           | Totals |
|----------------------------------------------------------|--------|
| <b>MITRE ATT&amp;CK® for ICS Techniques</b>              | 14     |
| <b>Technique Observables</b>                             | 48     |
| <b>Precursor Techniques</b>                              | 11     |
| <b>Precursor Technique Observables</b>                   | 44     |
| <b>Highly Perceivable Precursor Technique Observable</b> | 42     |

### 3. OBSERVABLE AND TECHNIQUE ANALYSIS

The following analysis may assist organizations in identifying malicious cyber activity earlier and more effectively. The following techniques and observables were compiled from publicly available sources and correlated with expert analysis.

#### 3.1. SPEARPHISHING ATTACHMENT TECHNIQUE (T0865) FOR INITIAL ACCESS

The adversaries behind Havex initially used malicious PDF documents in spearphishing emails sent to company executives and senior employees to deploy the malware into victim environments.<sup>8</sup> Spearphishing is a very common technique that both sophisticated and unsophisticated adversaries use to trick an unsuspecting end-user into installing malware by interacting with a malicious attachment, such as a PDF of Microsoft Office document. Email is one of the most popular vectors for an adversary to gain initial access into a victim environment. In the case of Havex, the spearphishing emails had titles like “*The Account*” and “*Settlement of delivery problem*”.<sup>9</sup> The adversaries also used an exploit that allowed the embedded Havex payload to be executed within an XML-based companion to a PDF file, known as an XDP file.<sup>10</sup>

Targeted observers such as Support Staff and Management are the most likely to have observed this technique before any embedded malicious payload was executed. Spearphishing emails present an early perception opportunity for personnel as there are several cognitive processes that end-users can learn to determine if an email with an attachment is suspicious, even without interacting with it. One potential perception opportunity could be a solution as simple as “external” tags on all emails originating from outside the organization.

A total of five observables were identified with the use of the [Spearphishing Attachment technique \(T0865\)](#). This technique is important for investigation because it often is one of the first tactics an adversary would pursue to gain initial access. This technique is important for investigation, as it appears early and is often the first observable opportunity for end-users. Responding to this technique could potentially halt an attack early in the attack chain.

All five observables are assessed to be highly perceivable (Spearphishing Email; Malicious XML Attachments; Malicious XDP Attachments; Malicious PDF Attachments; Anomalous Downloads over HTTP).

Please see [Appendix A](#) for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                                      |
|---------------------------------------------------------------|--------------------------------------------------------------------------------------|
| Artifacts                                                     | A total of 29 artifacts could be generated by the Spearphishing Attachment technique |
| Technique Observers <sup>b</sup>                              | Support Staff and Management                                                         |
| Resources                                                     | <a href="#">Technique Detection References</a>                                       |

<sup>b</sup> Observer titles are adapted from the Job Role Groupings listed in [the SANS ICS Job Role to Competency Level Poster](#). CyOTE products utilize these job categories rather than organizational titles to both support comprehensive analysis and preserve anonymity within the victim organization. A complete list of potential observers can be found in [Appendix C](#).

### 3.2. DRIVE-BY COMPROMISE TECHNIQUE (T0817) FOR INITIAL ACCESS

The adversaries behind Havex also utilized drive-by compromises, also known as watering hole attacks, to spread and install the malware in targeted environments.<sup>11</sup> Specifically, the adversaries made use of iframes and several exploit kits to redirect the user's browser session to a second website that hosted the Havex payload.<sup>12</sup> Once the user's browser visited the compromised site, the victim's machine would download and execute Havex. The adversary targeted and infected websites of interest to the victim, which increased the likelihood a victim would interact with the compromised site.<sup>13</sup>

Observables include normal interaction with websites of interest to personnel in an organization, which severely hampers a perceivable opportunity for the end-user. IT or OT Cybersecurity is somewhat likely to see anomalous download activity on a host depending on their visibility within their respective environment.

Potential observers of this technique include IT Staff, OT Staff, Engineers, Management, and Support Staff.

A total of two observables, neither of which are assessed to be highly observable, were identified with the use of the [Drive-By Compromise technique \(T0817\)](#). This technique appears early in the attack chain and detecting and responding to a drive-by compromise will limit an adversary's ability to gain initial access to a victim's environment.

Please see [Appendix A](#) for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                                 |
|---------------------------------------------------------------|---------------------------------------------------------------------------------|
| <b>Artifacts</b>                                              | A total of 24 artifacts could be generated by the Drive-By Compromise technique |
| <b>Technique Observers</b>                                    | IT Staff, Support Staff, Management, OT Staff, Engineers                        |
| <b>Resources</b>                                              | <a href="#">Technique Detection References</a>                                  |

### 3.3. SUPPLY CHAIN COMPROMISE TECHNIQUE (T0862) FOR INITIAL ACCESS

In the later stages of the campaign, the adversaries compromised three original equipment manufacturers (OEMs) of ICS software Havex could use to piggyback in a supply chain attack (T0862) deeper into the production environment.<sup>14</sup> The adversaries embedded the Havex payload in legitimate software downloads hosted on three OEM websites, which victims then downloaded. This almost certainly guaranteed successful execution and infection of any host receiving the updated software from the three OEMs.<sup>15</sup> Infection through a supply chain attack could be especially problematic if the update was installed in the operations zone: this would position Havex to execute and exfiltrate victim information from within the OT/production network.

Potential observers for this technique include engineers or staff responsible for downloading and installing updates such as OT Staff, IT Staff, Engineers, and Support Staff. These observers likely would have interacted normally with vendor websites and downloaded relevant software updates as needed.

This technique modifies the host operating system files via the download and installation of Havex, resulting in the host being placed into a modified state. Additionally, mismatched software hashes present a potential observable if OEMs publish verified hashes and adversaries did not manipulate them; however, this could be obfuscated by adversaries by editing the hash and would minimize perceivability by both the OEM and victim. Anomalous activity instantiated by the compromised software, such as anomalous outbound communications, would be highly perceivable.

A total of three observables were identified with the use of the [Supply Chain Compromise technique \(T0862\)](#). Supply chain attacks are notoriously stealthy and difficult for defenders to counter. This technique appears early in the attack timeline and is an effective means for an adversary to gain initial access. Terminating the attack chain at this point is unlikely to prevent Havex from scanning as the malware will still execute in a victim's environment upon installation.

All three observables are assessed to be highly perceivable (Modification of Host Operating Files; Registry Key Created; Anomalous Outbound Communication).

Please see [Appendix A](#) for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                                     |
|---------------------------------------------------------------|-------------------------------------------------------------------------------------|
| <b>Artifacts</b>                                              | A total of 31 artifacts could be generated by the Supply Chain Compromise technique |
| <b>Technique Observers</b>                                    | OT Staff, IT Staff, Engineers, Support Staff                                        |
| <b>Resources</b>                                              | <a href="#">Technique Detection References</a>                                      |

### 3.4. USER EXECUTION TECHNIQUE (T0863) FOR EXECUTION

A common factor among the three initial access vectors includes the User Execution technique (T0863) that triggers the download and installation of Havex malware onto a host. User actions that enable Havex infections include interacting with malicious email attachments in spearphishing emails, visiting a compromised website in a browser, and installing a trojan-infected update from an OEM. User execution is a common technique that adversaries regularly use to execute payloads within a victim's environment for follow-on activities such as reconnaissance or deployment of additional malicious software like ransomware.

Observers of and participants in this technique include all previously listed observers for the initial access phase. Observers include Management, IT Staff, IT Cybersecurity, OT Staff, Engineers, and Support Staff, as Havex leveraged multiple techniques related to initial access that hinge on user execution. These include malicious documents attached to spearphishing emails, drive-by compromises targeting vulnerable web browsers, and supply chain attacks. It is likely the most concrete perception opportunities for personnel are spearphishing emails as they are the least stealthy initial access technique among the three listed in this report.

This technique modifies the host operating system files via the download and installation of Havex, resulting in the host being placed into a modified state. If system backups are created after this technique is executed, data recovery and disaster recovery efforts will likely be impaired.

A total of three observables were identified with the use of the [User Execution technique \(T0863\)](#). This technique is important for investigation as it is extremely common among sophisticated and unsophisticated adversaries to use early in the attack chain. This technique appears early in the timeline and is somewhat likely for defenders to perceive given the initial access techniques covered in sections 3.1 to 3.3.

All three observables are assessed to be highly perceivable (Spearphishing Email; Malicious PDF Attachment; AutoStart Registry Key Created).

Please see [Appendix A](#) for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                            |
|---------------------------------------------------------------|----------------------------------------------------------------------------|
| <b>Artifacts</b>                                              | A total of 23 artifacts could be generated by the User Execution technique |
| <b>Technique Observers</b>                                    | Management, IT Staff, IT Cybersecurity, OT Staff, Engineers, Support Staff |
| <b>Resources</b>                                              | <a href="#">Technique Detection References</a>                             |

### 3.5. INDICATOR REMOVAL ON HOST TECHNIQUE (T0872) FOR EVASION

Havex wipes files from disk to avoid detection after conducting its reconnaissance on an infected host. Havex writes files to disk in the %TEMP%, %System32%, and %AppData% directories, and deletes files once the output of its automated reconnaissance is sent off to a command and control (C2) server.<sup>16</sup>

Observers of Havex's indicator removal capabilities include host administrators, IT Staff, IT Cybersecurity, and OT Cybersecurity. This technique occurs relatively late in Havex's timeline as the malware will wipe any outputs of techniques related to Discovery tactics.

A total of three observables were identified with the use of the [Indicator Removal on Host technique \(T0863\)](#). This technique is important for investigation as it is common among sophisticated and unsophisticated adversaries to use in an attack chain. This technique appears throughout the attack timeline and, although difficult, is not impossible for defenders such as host administrators to observe. Terminating the attack chain at this point would potentially stop the exfiltration of operational information.

All three observables are assessed to be highly perceivable (Creation of .tmp, .dat, or .yls Files; Deletion of .tmp, .dat, or .yls Files; Deletion of Registry Keys).

Please see [Appendix A](#) for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                                       |
|---------------------------------------------------------------|---------------------------------------------------------------------------------------|
| <b>Artifacts</b>                                              | A total of 23 artifacts could be generated by the Indicator Removal on Host technique |
| <b>Technique Observers</b>                                    | IT Staff, IT Cybersecurity, OT Cybersecurity                                          |
| <b>Resources</b>                                              | <a href="#">Technique Detection References</a>                                        |

### 3.6. REMOTE SYSTEM DISCOVERY TECHNIQUE (T0846) FOR DISCOVERY

Havex's network scanning capabilities provide its base reconnaissance function to gain insight into the target's environment through the Remote System Discovery technique (T0846). Havex can identify networked assets in the Local Area Network (LAN) using Windows Network (Wnet) calls.<sup>17,18</sup> Outputs of this baseline scanning activity determine what types of assets Havex will scan for next and are discussed in subsequent technique sections.

Observers include IT Staff, OT Staff, IT Cybersecurity, and OT Cybersecurity. These observers would likely see anomalous ARP (Address Resolution Protocol) traffic in the form of ARP requests to generate a series of replies from networked devices in that LAN.<sup>19</sup> Terminating the chain of techniques at this point would likely prevent the malware from spreading to other systems and conducting further reconnaissance.

A total of four observables were identified with the use of the [Remote System Discovery technique \(T0846\)](#). This technique appears early in the Havex timeline; Havex conducts this scanning as a basis for later reconnaissance activities.

All four observables associated with this technique are assessed to be highly perceivable (Anomalous ARP Requests; Anomalous ARP Replies; WNetOpenEnum API Calls; WNetEnumResources API Calls).

Please see [Appendix A](#) for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                                     |
|---------------------------------------------------------------|-------------------------------------------------------------------------------------|
| <b>Artifacts</b>                                              | A total of 43 artifacts could be generated by the Remote System Discovery technique |
| <b>Technique Observers</b>                                    | IT Staff, OT Staff, IT Cybersecurity, OT Cybersecurity                              |
| <b>Resources</b>                                              | <a href="#">Technique Detection References</a>                                      |

### 3.7. REMOTE SYSTEM INFORMATION DISCOVERY TECHNIQUE (T0888) FOR DISCOVERY

Havex can enumerate any networked OPC assets within a victim's environment via the Remote System Information Discovery technique (T0888). After mapping the victim's general network topography, Havex also scans hard-coded ports commonly used in industrial environments such as TCP/IP Ports 102 (Siemens S7), 502 (Schneider Electric), and 44818 (Rockwell Automation).<sup>20</sup> Havex also scans for Microsoft Distributed Component Object Model (COM/DCOM) interfaces.<sup>21,22</sup> If Havex receives a response to its COM/DCOM requests, Havex will then seek out specific OPC attributes, as detailed in a later technique section.

Observers of this scanning activity include IT Staff, OT Staff, IT Cybersecurity, OT Cybersecurity, who could observe abnormal scanning across a LAN on the listed TCP ports as well as anomalous COM/DCOM traffic.

A total of eight observables were identified with the use of the [Remote System Information Discovery technique \(T0888\)](#). This technique is important for investigation as anomalous scanning is an indicator of either a reliability issue or potential malicious activity in an enterprise or operations environment. This technique appears near the middle of the Havex attack chain. Terminating the attack chain at this point would likely prevent any additional scanning, including any that interferes with OPC assets, which is detailed in a later technique.

All eight observables are assessed to be highly perceivable (Anomalous Scanning over TCP Port 102; Anomalous Scanning over TCP Port 502; Anomalous Scanning over TCP Port 11234; Anomalous Scanning over TCP Port 12401; Anomalous Scanning over TCP Port 44818; Scanning over TCP Port 135; Anomalous COM/DCOM Traffic; Anomalous DCE/RPC Calls).

Please see [Appendix A](#) for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                                                |
|---------------------------------------------------------------|------------------------------------------------------------------------------------------------|
| Artifacts                                                     | A total of 8 artifacts could be generated by the Remote System Information Discovery technique |
| Technique Observers                                           | IT Staff, OT Staff, IT Cybersecurity, OT Cybersecurity                                         |
| Resources                                                     | <a href="#">Technique Detection References</a>                                                 |

### 3.8. POINT AND TAG IDENTIFICATION TECHNIQUE (T0861) FOR COLLECTION

After determining if a networked asset responds to COM/DCOM traffic, Havex collects information specific to OPC assets as part of the Point and Tag Identification technique. OPC allows Windows-based software to interact across numerous proprietary vendor protocols, simplifying inter-device communications within modern industrial environments. OPC assets use labels known as “points” and “tags” to reference various aspects of an OPC server or client. “Points” include values such as inputs, outputs, and other process-specific values and “tags” are labels given to various points for operator convenience.<sup>23</sup> Havex is capable of Point and Tag Identification (T0861) and searches for attributes such as server state, class identification, tag name, type, access, and identification number.<sup>24</sup> This information would be key to an adversary for either industrial espionage or as preparation for more tailored malicious cyber activity against that facility.

Observers of this technique include OT Staff and OT Cybersecurity. These observers likely would have seen unusual scanning from previous techniques, as well as anomalous OPC traffic. OPC Data Access (DA) is documented to run on TCP Port 135 but there are other ephemeral port configurations depending on facility requirements.

A total of five observables were identified with the use of the [Point and Tag Identification technique \(T0861\)](#). Randomly generated network traffic that is indicative of scanning within a victim’s network is a perception opportunity for defenders, likely prompting an investigation. This technique appears late in the timeline for Havex. Identifying the source of this activity, like the above techniques, presents a key comprehension opportunity for defenders. Termination of the attack chain at this stage would prevent any identification of exfiltration of information related to networked OPC assets.

All five observables are assessed to be highly perceivable (Scanning over TCP Port 135; Anomalous Scanning over TCP Port 1024-65535; Creation of OPCServer[random].txt files in %TEMP% Directory; ColnitalizeEx API Calls; CoCreateInstance API calls).

Please see [Appendix A](#) for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                                          |
|---------------------------------------------------------------|------------------------------------------------------------------------------------------|
| <b>Artifacts</b>                                              | A total of 53 artifacts could be generated by the Point and Tag Identification technique |
| <b>Technique Observers</b>                                    | OT Staff, OT Cybersecurity                                                               |
| <b>Resources</b>                                              | <a href="#">Technique Detection References</a>                                           |

### 3.9. AUTOMATED COLLECTION TECHNIQUE (T0802) FOR COLLECTION

Once Havex has mapped the victim's network and enumerated OPC assets, the malware then automatically collects data using the Automated Collection technique (T0802), compiles the results, encrypts the data, then sends it to a C2 server.

Havex outputs the scan results into a .txt file with the name of the OPC asset it identified, such as OPCServer[random].txt.dat, encrypts the .txt file in the %TEMP% directory, then sends the output to an external C2 server.<sup>25,26,27</sup>

Observers of this technique include IT Staff, OT Staff, IT Cybersecurity, and OT Cybersecurity staff.

A total of four observables were identified with the use of the [Automated Collection technique \(T0802\)](#). This technique appears late in the Havex attack chain. Terminating the chain of techniques at this point is somewhat likely to prevent Havex from exfiltrating data from the victim to a C2 under the adversary's control.

All four observables are assessed to be highly perceivable (Exfil Victim Data to C2 Server; Creation of .txt, .dat, or .yls File Containing Output of Havex OPC Reconnaissance Module; Encryption of .txt or .dat file; Creation of AutoStart Registry Key).

Please see [Appendix A](#) for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                                  |
|---------------------------------------------------------------|----------------------------------------------------------------------------------|
| <b>Artifacts</b>                                              | A total of 23 artifacts could be generated by the Automated Collection technique |
| <b>Technique Observers</b>                                    | IT Staff, OT Staff, IT Cybersecurity, OT Cybersecurity staff                     |
| <b>Resource</b>                                               | <a href="#">Technique Detection References</a>                                   |

### 3.10. COMMONLY USED PORT TECHNIQUE (T0885) FOR COMMAND AND CONTROL

Havex utilizes the Commonly Used Ports technique (T0855) for its C2 traffic. Specifically, Havex uses HTTP over TCP/IP Port 80 to communicate with C2 servers.<sup>28</sup>

IT Cybersecurity, OT Cybersecurity, and IT Staff would likely be able to perceive C2 traffic, especially if Havex is attempting to communicate from a properly segmented production environment.

A total of three observables were identified with the use of the [Commonly Used Port technique \(T0885\)](#). This technique is important for investigation as it appears throughout Havex's attack timeline, which would allow defenders a greater opportunity to detect network activity between the malware and its C2 infrastructure. Terminating the attack chain here could either identify malicious activity in a victim's environment or prevent the malware from exfiltrating operational information to a C2 server.

All three observables are assessed to be highly perceivable (Traffic over TCP Port 80; HTTP GET Requests; HTTP POST Requests).

Please see [Appendix A](#) for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                               |
|---------------------------------------------------------------|-------------------------------------------------------------------------------|
| <b>Artifacts</b>                                              | A total of 5 artifacts could be generated by the Commonly Used Port technique |
| <b>Technique Observers</b>                                    | IT Staff, IT Cybersecurity, OT Cybersecurity                                  |
| <b>Resources</b>                                              | <a href="#">Technique Detection References</a>                                |

### 3.11. STANDARD APPLICATION LAYER PROTOCOL TECHNIQUE (T0869) FOR COMMAND AND CONTROL

Havex uses the Standard Application Layer Protocol technique (T0869) to communicate with its C2 servers through HTTP.<sup>29,30</sup>

Observers of this technique include network administrators, IT Staff, IT Cybersecurity, and OT Cybersecurity.

This technique is important for investigation as it presents a detection and perception opportunity for defenders that warrants investigation, especially within a production environment. Terminating the attack chain here could either identify malicious activity in a victim's environment or prevent the malware from exfiltrating operational information to a C2 server.

A total of three observables were identified with the use of the [Standard Application Layer Protocol technique](#).

All three observables are assessed to be highly perceivable (HTTP Traffic on TCP/80; HTTP GET Requests; HTTP POST Requests).

Please see [Appendix A](#) for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                                                 |
|---------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| <b>Artifacts</b>                                              | A total of 12 artifacts could be generated by the Standard Application Layer Protocol technique |
| <b>Technique Observers</b>                                    | OT Cybersecurity, IT Staff, IT Cybersecurity                                                    |
| <b>Resources</b>                                              | <a href="#">Technique Detection References</a>                                                  |

### 3.12. DENIAL OF SERVICE TECHNIQUE (T0814) FOR INHIBIT RESPONSE FUNCTION

Although multiple researchers and vendors have stated that Havex was designed with the intent to inhibit processes or cause damage to assets in industrial control environments, ICS-CERT observed in testing that multiple OPC platforms crashed after a Havex infection, likely due to Havex's OPC scanning capabilities.<sup>31,32</sup> In such cases, a temporary denial of service effect could cause a denial of control incident for assets reliant on OPC for operation and control.<sup>33</sup>

Observers of this technique include OT Staff, OT Cybersecurity, and Engineers. These observers likely observe OPC clients or servers behaving abnormally or not functioning properly when in use.

A total of three observables were identified with the use of the [Denial of Service technique \(T0882\)](#). This technique is important for investigation as malfunctioning OPC assets represents a triggering event warranting investigation by an organization. Terminating the attack chain here would stop any active scanning conducted by the malware as well as prevent the exfiltration of operational information.

All three observables are assessed to be highly perceivable (OPC Clients not Functioning; OPC Servers not Functioning; Abnormal OPC Traffic).

Please see [Appendix A](#) for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                               |
|---------------------------------------------------------------|-------------------------------------------------------------------------------|
| <b>Artifacts</b>                                              | A total of 14 artifacts could be generated by the Denial of Service technique |
| <b>Technique Observers</b>                                    | OT Staff, OT Cybersecurity, Engineers                                         |
| <b>Resources</b>                                              | <a href="#">Technique Detection References</a>                                |

### 3.13. THEFT OF OPERATIONAL INFORMATION TECHNIQUE (T0882) FOR IMPACT

After its automated reconnaissance is complete, Havex exfiltrates the output of its activities to an external C2 server. In addition to mapping network infrastructure and identifying OPC assets, Havex can also harvest credentials from applications such as email clients and web browsers used in enterprise environments. Havex outputs the results of its reconnaissance module into a .txt file, and then encrypts the .txt file into a .yls format, which helps ensure a casual observer would not know the purpose of such a file.<sup>34,35</sup>

Observers of this technique include IT Cybersecurity, OT Cybersecurity, and IT Staff such as host administrators. These observers likely would have observed brief activity within several common file directories on a compromised host along with the creation and deletion of several .txt and .yls files.

A total of three observables were identified with the use of the [Theft of Operational Information technique \(T0882\)](#). This technique is important for investigation because it represents an exfiltration of victim information that could be used in either industrial espionage or sabotage. This technique appears at the end of the attack chain beyond the point where a defender could take action to disrupt the attack.

All three observables are assessed to be highly perceivable (Creation of .txt or .dat File Containing Output of Havex's Activities; Deletion of .txt File; Deletion of .dat File; Deletion of .yls File, Anomalous Outbound Communications Over HTTP).

Please see [Appendix A](#) for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                                             |
|---------------------------------------------------------------|---------------------------------------------------------------------------------------------|
| <b>Artifacts</b>                                              | A total of 4 artifacts could be generated by the Theft of Operational Information technique |
| <b>Technique Observers</b>                                    | IT Staff, IT Cybersecurity, OT Cybersecurity                                                |
| <b>Resources</b>                                              | <a href="#">Technique Detection References</a>                                              |

### 3.14. DENIAL OF CONTROL TECHNIQUE (T0813) FOR IMPACT

Multiple researchers and vendors have stated Havex was not capable of explicit destructive capability and was likely not designed to do so.<sup>36</sup> However, during testing ICS-CERT observed multiple OPC devices crashing due to Havex.<sup>37,38</sup> This is likely due to unforeseen errors stemming from Havex's OPC scanning module. The temporary denial of service effect on assets reliant on OPC could result in a temporary denial of control incident where operators who rely on OPC cannot control assets within an OT environment.

Observers of this technique include OT Staff, OT Cybersecurity, Engineers, and Plant Managers. These observers would likely witness industrial assets triggering alarms as they malfunction or crash. This technique is important for investigation because it represents a triggering event driven by reliability issues or potential malicious cyber activity. Terminating the attack chain here is not likely to prevent the exfiltration of Havex's reconnaissance data due to the immediacy of this technique.

One observable, assessed to be highly perceivable, was identified with the use of the [Denial of Control technique \(T0813\)](#) (OPC Assets Unable to be Controlled).

Please see [Appendix A](#) for the list of observables.

| CyOTE Capabilities for Technique Perception and Comprehension |                                                                              |
|---------------------------------------------------------------|------------------------------------------------------------------------------|
| <b>Artifacts</b>                                              | A total of 8 artifacts could be generated by the Denial of Control technique |
| <b>Technique Observers</b>                                    | OT Staff, OT Cybersecurity Staff, Engineers, Plant Managers                  |
| <b>Resources</b>                                              | <a href="#">Technique Detection References</a>                               |

## APPENDIX A: OBSERVABLES LIBRARY

| Observables Associated with Spearphishing Attachment Technique (T0865) |                                                                                                                            |
|------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------|
| <b>Observable 1</b>                                                    | Victims Received Spearphishing Emails Designed To Trick End Users Into Interacting With Malicious Attachments              |
| <b>Observable 2</b>                                                    | Victims Interacted With Malicious Adobe Documents In Spearphishing Emails That Would Install The Havex Malware Onto A Host |
| <b>Observable 3</b>                                                    | The Attached Malicious XML Documents Would Trigger A Download Of The Havex Payload                                         |
| <b>Observable 4</b>                                                    | The Attached Malicious XDP Documents Would Trigger A Download Of The Havex Payload                                         |
| <b>Observable 5</b>                                                    | The Attached Malicious PDF Documents Would Trigger A Download Of The Havex Payload                                         |

| Observables Associated with Drive-by Compromise Technique (T0817) |                                                                                                    |
|-------------------------------------------------------------------|----------------------------------------------------------------------------------------------------|
| <b>Observable 1</b>                                               | Iframes Were Placed On Compromised Websites To Redirect Victims To Sites Hosting The Havex Payload |
| <b>Observable 2</b>                                               | Victims Visiting Compromised Websites Were Re-Routed To A Website Hosting The Havex Malware        |

| Observables Associated with Supply Chain Compromise Technique (T0862) |                                                                                                                                         |
|-----------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------|
| <b>Observable 1</b>                                                   | Victims Unknowingly Downloaded Compromised Software That Contained An Embedded Havex Payload                                            |
| <b>Observable 2</b>                                                   | Victims Could Perceive Anomalous Outbound Traffic Upon Installation Of The Trojanized Software Updates; HTTP                            |
| <b>Observable 3</b>                                                   | Downloading The Trojanized Software Update Would Modify Host Files, Thereby Instantiating Malicious Activity Such As Anomalous Scanning |

| Observables Associated with User Execution Technique (T0863) |                                                                                                               |
|--------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------|
| <b>Observable 1</b>                                          | Victims Received Spearphishing Emails Designed To Trick End Users Into Interacting With Malicious Attachments |
| <b>Observable 2</b>                                          | Victims Interacted With Malicious Adobe PDF Documents That Would Install The Havex Malware Onto A Host        |
| <b>Observable 3</b>                                          | Havex Would Create An Autostart Registry Key To Maintain Persistence                                          |

| Observables Associated with Indicator Removal on Host Technique (T0872) |                                                                                                                               |
|-------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------|
| <b>Observable 1</b>                                                     | Havex Deleted Files In %TEMP%, %Appdata%, %System32% Directories On Disk After Its Reconnaissance Activities Were Complete    |
| <b>Observable 2</b>                                                     | Havex wrote and deleted files in several host directories on disk: Files Deleted in %TEMP%, %AppData%, %System32% Directories |

**Observables Associated with Indicator Removal on Host Technique (T0872)**

|                     |                                                                                          |
|---------------------|------------------------------------------------------------------------------------------|
| <b>Observable 3</b> | Havex Created Then Deleted .tmp Files On An Infected Host: .tmp Files Created Or Deleted |
| <b>Observable 4</b> | Havex Created Then Deleted .yls Files On An Infected Host: .yls Files Created Or Deleted |
| <b>Observable 5</b> | Havex Created Then Deleted .dat Files On An Infected Host: .dat Files Created Or Deleted |

**Observables Associated with Remote System Discovery Technique (T0846)**

|                     |                                                                                                         |
|---------------------|---------------------------------------------------------------------------------------------------------|
| <b>Observable 1</b> | Havex Used ARP Requests To Identify Networked Assets For Further Reconnaissance: Anomalous ARP Requests |
| <b>Observable 2</b> | Havex Used ARP Replies To Identify Networked Assets For Further Reconnaissance: Anomalous ARP Replies   |

**Observables Associated with Remote System Information Discovery Technique (T0888)**

|                     |                                                                                                                                                                                                     |
|---------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Observable 1</b> | Havex Scanned On TCP PORT 102, A Port Associated With Siemens PLCs: Anomalous Traffic On TCP PORT 102                                                                                               |
| <b>Observable 2</b> | Havex Scanned On TCP PORT 502, A Port Associated With Modbus Over Ethernet: Anomalous Traffic On TCP PORT 502                                                                                       |
| <b>Observable 3</b> | Havex Scanned On TCP PORT 11234, A Port Associated With ScadaPro Communications: Anomalous Traffic On TCP PORT 11234                                                                                |
| <b>Observable 4</b> | Havex Scanned On TCP PORT 12401, A Port Associated With 7-Technologies Graphical SCADA, GE Proficy License Server Manager, And WellinTech KingSCADA: Anomalous Traffic On TCP PORT 12401            |
| <b>Observable 5</b> | Havex Scanned On TCP PORT 44818, A Port Associated With Rockwell Automation Software, Tec4Data Smartcooler, And Cisco IOS Common Industrial Protocol Processor: Anomalous Traffic On TCP PORT 44818 |
| <b>Observable 6</b> | Havex Scanned On TCP PORT 135, A Port Associated With OPC DA: Anomalous Traffic On TCP PORT 135                                                                                                     |
| <b>Observable 7</b> | Havex Scanned For COM And DCOM Objects To Help Identify Any OPC Assets In A LAN: Non-Standard COM/DCOM Traffic                                                                                      |
| <b>Observable 8</b> | DCOM Uses DCE As Its Transport Layer: DCE/RPC Calls                                                                                                                                                 |

**Observables Associated with Point and Tag Identification Technique (T0861)**

|                     |                                                                                                                                                                             |
|---------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Observable 1</b> | Havex Scanned Over TCP PORT 135 As OPC DA Is Associated With This Port, To Collect OPC-Specific Attributes: Scanning Over TCP PORT 135                                      |
| <b>Observable 2</b> | Havex May Have Scanned On Other Ports Associated With OPC DA, As OPC DA Can Be Configured To Use Other Default Ephemeral Ports: Anomalous Scanning Over TCP PORT 1024-65535 |

**Observables Associated with Automated Collection Technique (T0802)**

|                     |                                                                                                                                       |
|---------------------|---------------------------------------------------------------------------------------------------------------------------------------|
| <b>Observable 1</b> | Havex Exfiltrated Its Scanning Output To An Adversary Controlled C2 Server                                                            |
| <b>Observable 2</b> | Havex Created .txt Files Of Its Reconnaissance Outputs                                                                                |
| <b>Observable 3</b> | Havex Created Encrypted .yls Files From The .txt Files That Contained The Results Of Its Scanning Activities                          |
| <b>Observable 4</b> | Havex Created An Autostart Registry Key To Execute The Malware When A User Logs In, Helping To Ensure Persistence On An Infected Host |

**Observables Associated with Commonly Used Port Technique (T0885)**

|                     |                                                                                                                             |
|---------------------|-----------------------------------------------------------------------------------------------------------------------------|
| <b>Observable 1</b> | Havex Used HTTP For Its C2 Traffic, Which Uses TCP Port 80: Traffic Over TCP Port 80                                        |
| <b>Observable 2</b> | Havex Used HTTP GET Requests To Communicate With Its C2 Server Or Download Additional Modules: HTTP GET Requests            |
| <b>Observable 3</b> | Havex Used HTTP POST Requests To Communicate With Its C2 Server Or Exfiltrate Its Reconnaissance Output: HTTP POST Requests |

**Observables Associated with Standard Application Layer Protocol Technique (T0869)**

|                     |                                                                                                                       |
|---------------------|-----------------------------------------------------------------------------------------------------------------------|
| <b>Observable 1</b> | Havex Used HTTP GET Requests To Download Additional Modules Or Receive Commands From Its C2 Server: HTTP GET Requests |
| <b>Observable 2</b> | Havex Used HTTP POST Requests To Exfiltrate Its Scanning Output: HTTP POST Requests                                   |
| <b>Observable 3</b> | Havex Used HTTP For Its C2 Traffic: HTTP                                                                              |

**Observables Associated with Denial of Service Technique (T0814)**

|                     |                                                                                                        |
|---------------------|--------------------------------------------------------------------------------------------------------|
| <b>Observable 1</b> | Havex Was Observed Causing OPC Clients To Malfunction Due To Errors Related To Its Scanning Activities |
| <b>Observable 2</b> | Havex Was Observed Causing OPC Servers To Malfunction Due To Errors Related To Its Scanning Activities |
| <b>Observable 3</b> | Havex Scanned OPC Assets, Generating Additional And Abnormal OPC Traffic In An Environment             |

**Observables Associated with Theft of Operational Information Technique (T0882)**

|                     |                                                                                                       |
|---------------------|-------------------------------------------------------------------------------------------------------|
| <b>Observable 1</b> | Havex Would Exfiltrate The Output Of Its Reconnaissance To Its C2 Server: HTTP Traffic                |
| <b>Observable 2</b> | Havex Created Then Deleted .tmp Files On An Infected Host Pertaining To Its Reconnaissance Activities |
| <b>Observable 3</b> | Havex Created Then Deleted .yls Files On An Infected Host Pertaining To Its Reconnaissance Activities |
| <b>Observable 4</b> | Havex Created Then Deleted .dat Files On An Infected Host Pertaining To Its Reconnaissance Activities |

**Observables Associated with Denial of Control Technique (T0813)****Observable 1**

Havex Could Cause Organizations To Temporarily Lose Control Of Certain Assets Reliant On OPC Due To Unforeseen Errors Associated With Havex's Scanning Activities

## APPENDIX B: ARTIFACTS LIBRARY

| Artifacts Associated with Spearphishing Attachment Technique (T0865) |                                             |
|----------------------------------------------------------------------|---------------------------------------------|
| Artifact 1                                                           | Mismatch MIME and Attachment File Extension |
| Artifact 2                                                           | Email Sender Address                        |
| Artifact 3                                                           | Email Message                               |
| Artifact 4                                                           | Email Receiver                              |
| Artifact 5                                                           | Email Receiver Name                         |
| Artifact 6                                                           | Email Receiver Domain                       |
| Artifact 7                                                           | Email Receiver Address                      |
| Artifact 8                                                           | Enable Macros Pop-Up                        |
| Artifact 9                                                           | Email Application Log File                  |
| Artifact 10                                                          | Email Unified Audit Log File                |
| Artifact 11                                                          | Email Service Name                          |
| Artifact 12                                                          | Suspicious Email Message Content            |
| Artifact 13                                                          | Operating System Service Creation           |
| Artifact 14                                                          | Email .pst File                             |
| Artifact 15                                                          | Email .ost File                             |
| Artifact 16                                                          | Simple Mail Transfer Protocol SMTP Traffic  |
| Artifact 17                                                          | Mail Transfer Agent Logs                    |
| Artifact 18                                                          | Email Parent Process                        |
| Artifact 19                                                          | Mail Transfer Agent Logs                    |
| Artifact 20                                                          | Email Domain Name System DNS Traffic        |
| Artifact 21                                                          | Email Domain Name System DNS Event          |
| Artifact 22                                                          | File Attachment Warning Prompt              |
| Artifact 23                                                          | Email Timestamp                             |
| Artifact 24                                                          | Email Attachment                            |
| Artifact 25                                                          | Email Attachment File Type                  |
| Artifact 26                                                          | Email Header                                |
| Artifact 27                                                          | Email Sender Name                           |
| Artifact 28                                                          | Email Sender IP Address                     |
| Artifact 29                                                          | Email Sender Domain                         |

| Artifacts Associated with Drive-by Compromise Technique (T0817) |                 |
|-----------------------------------------------------------------|-----------------|
| Artifact 1                                                      | Application Log |

| Artifacts Associated with Drive-by Compromise Technique (T0817) |                                   |
|-----------------------------------------------------------------|-----------------------------------|
| <b>Artifact 2</b>                                               | cmd.exe Application Start         |
| <b>Artifact 3</b>                                               | Dialog Boxes Open                 |
| <b>Artifact 4</b>                                               | POWERSHELL Cmdlet Open            |
| <b>Artifact 5</b>                                               | POWERSHELL Log Creation           |
| <b>Artifact 6</b>                                               | Source IP Address                 |
| <b>Artifact 7</b>                                               | Destination IP Address            |
| <b>Artifact 8</b>                                               | File Creation                     |
| <b>Artifact 9</b>                                               | Memory Evidence                   |
| <b>Artifact 10</b>                                              | Disk Read                         |
| <b>Artifact 11</b>                                              | Disk Write                        |
| <b>Artifact 12</b>                                              | TLS Certificates                  |
| <b>Artifact 13</b>                                              | Website                           |
| <b>Artifact 14</b>                                              | Industrial Application Process    |
| <b>Artifact 15</b>                                              | Industrial Application Disk Write |
| <b>Artifact 16</b>                                              | Prefetch Files                    |
| <b>Artifact 17</b>                                              | .LNK Files                        |
| <b>Artifact 18</b>                                              | HTTP Traffic                      |
| <b>Artifact 19</b>                                              | DNS Traffic                       |
| <b>Artifact 20</b>                                              | HTTPS Traffic                     |
| <b>Artifact 21</b>                                              | SMB Traffic                       |
| <b>Artifact 22</b>                                              | Process Creation                  |
| <b>Artifact 23</b>                                              | Process Ending                    |
| <b>Artifact 24</b>                                              | Child Processes Created           |

| Artifacts Associated with Supply Chain Compromise Technique (T0862) |                            |
|---------------------------------------------------------------------|----------------------------|
| <b>Artifact 1</b>                                                   | DNS Queries Traffic Port   |
| <b>Artifact 2</b>                                                   | MAC Address                |
| <b>Artifact 3</b>                                                   | Source IP Address          |
| <b>Artifact 4</b>                                                   | Destination IP Address     |
| <b>Artifact 5</b>                                                   | Network Discover Protocols |
| <b>Artifact 6</b>                                                   | SMB Port                   |
| <b>Artifact 7</b>                                                   | SNMP Port                  |
| <b>Artifact 8</b>                                                   | LLDP Requests              |

| Artifacts Associated with Supply Chain Compromise Technique (T0862) |                                                     |
|---------------------------------------------------------------------|-----------------------------------------------------|
| <b>Artifact 9</b>                                                   | HTTP Port                                           |
| <b>Artifact 10</b>                                                  | Ping Echo Port                                      |
| <b>Artifact 11</b>                                                  | Static Source IP Address                            |
| <b>Artifact 12</b>                                                  | Usage of Default Account                            |
| <b>Artifact 13</b>                                                  | Usage of Vendor Maintenance Account                 |
| <b>Artifact 14</b>                                                  | Domain Name                                         |
| <b>Artifact 15</b>                                                  | Domain Registrant Data                              |
| <b>Artifact 16</b>                                                  | Domain IP Resolution                                |
| <b>Artifact 17</b>                                                  | Domain Autonomous System Number                     |
| <b>Artifact 18</b>                                                  | Hardware Serial Number Missing                      |
| <b>Artifact 19</b>                                                  | Additional Hardware Inserted on Devices             |
| <b>Artifact 20</b>                                                  | Mismatched Software Hashes                          |
| <b>Artifact 21</b>                                                  | Device Failures                                     |
| <b>Artifact 22</b>                                                  | Device Incompatibility Issues                       |
| <b>Artifact 23</b>                                                  | Hardware Tampering Evidence                         |
| <b>Artifact 24</b>                                                  | Hardware Failed Site Acceptance Test                |
| <b>Artifact 25</b>                                                  | Physical Defects to Hardware                        |
| <b>Artifact 26</b>                                                  | Unscheduled FIRMWARE Updates                        |
| <b>Artifact 27</b>                                                  | Manipulation of Signature on Digital Certifications |
| <b>Artifact 28</b>                                                  | Inconsistencies in Software Bill of Materials       |
| <b>Artifact 29</b>                                                  | Inconsistencies in Hardware Bill of Materials       |
| <b>Artifact 30</b>                                                  | Factory Acceptance Test Failure                     |
| <b>Artifact 31</b>                                                  | Inaccurate Delivery Based on Design Documents       |

| Artifacts Associated with User Execution Technique (T0863) |                          |
|------------------------------------------------------------|--------------------------|
| <b>Artifact 1</b>                                          | Application Log          |
| <b>Artifact 2</b>                                          | Prefetch Files           |
| <b>Artifact 3</b>                                          | System Log               |
| <b>Artifact 4</b>                                          | Registry Modification    |
| <b>Artifact 5</b>                                          | File Modifications       |
| <b>Artifact 6</b>                                          | File Renaming            |
| <b>Artifact 7</b>                                          | System Patches Installed |
| <b>Artifact 8</b>                                          | Files Opening            |

| Artifacts Associated with User Execution Technique (T0863) |                                           |
|------------------------------------------------------------|-------------------------------------------|
| <b>Artifact 9</b>                                          | File Signature Validation                 |
| <b>Artifact 10</b>                                         | Installers Created                        |
| <b>Artifact 11</b>                                         | Process Termination                       |
| <b>Artifact 12</b>                                         | File Creation                             |
| <b>Artifact 13</b>                                         | Service Termination                       |
| <b>Artifact 14</b>                                         | File Changes                              |
| <b>Artifact 15</b>                                         | User Account Modification                 |
| <b>Artifact 16</b>                                         | Increased ICMP Traffic (Network Scanning) |
| <b>Artifact 17</b>                                         | File Execution                            |
| <b>Artifact 18</b>                                         | Network Traffic Changes                   |
| <b>Artifact 19</b>                                         | Process Creation                          |
| <b>Artifact 20</b>                                         | Network Connection Creation               |
| <b>Artifact 21</b>                                         | Command Execution                         |
| <b>Artifact 22</b>                                         | Application Log Content                   |
| <b>Artifact 23</b>                                         | Application Installation                  |

| Artifacts Associated with Indicator Removal on Host Technique (T0872) |                                              |
|-----------------------------------------------------------------------|----------------------------------------------|
| <b>Artifact 1</b>                                                     | Command Execution                            |
| <b>Artifact 2</b>                                                     | User Logon Event                             |
| <b>Artifact 3</b>                                                     | User Logoff Event                            |
| <b>Artifact 4</b>                                                     | Windows Registry Key Deletion                |
| <b>Artifact 5</b>                                                     | Windows Registry Key Modification            |
| <b>Artifact 6</b>                                                     | HMI Dialog Box Open                          |
| <b>Artifact 7</b>                                                     | HMI Dialog Box Close                         |
| <b>Artifact 8</b>                                                     | HMI Screen Changes                           |
| <b>Artifact 9</b>                                                     | Process Creation                             |
| <b>Artifact 10</b>                                                    | HMI Interface Manipulation                   |
| <b>Artifact 11</b>                                                    | API System Calls                             |
| <b>Artifact 12</b>                                                    | File Creation                                |
| <b>Artifact 13</b>                                                    | Missing Log Events                           |
| <b>Artifact 14</b>                                                    | Memory Writes                                |
| <b>Artifact 15</b>                                                    | Unexpected Reboots                           |
| <b>Artifact 16</b>                                                    | Windows Security Log 1102 for Cleared Events |

| Artifacts Associated with Indicator Removal on Host Technique (T0872) |                             |
|-----------------------------------------------------------------------|-----------------------------|
| <b>Artifact 17</b>                                                    | File Deletion               |
| <b>Artifact 18</b>                                                    | File Modification           |
| <b>Artifact 19</b>                                                    | Sdelete Executable Loaded   |
| <b>Artifact 20</b>                                                    | Sdelete Executable Executed |
| <b>Artifact 21</b>                                                    | File Metadata Changes       |
| <b>Artifact 22</b>                                                    | Timestamp Inconsistencies   |
| <b>Artifact 23</b>                                                    | User Authentication         |

| Artifacts Associated with Remote System Discovery Technique (T0846) |                                                               |
|---------------------------------------------------------------------|---------------------------------------------------------------|
| <b>Artifact 1</b>                                                   | Common Network Traffic                                        |
| <b>Artifact 2</b>                                                   | IEC 103 Traffic (For North America)                           |
| <b>Artifact 3</b>                                                   | IEC 61850 MMS and                                             |
| <b>Artifact 4</b>                                                   | Controller Proprietary Traffic                                |
| <b>Artifact 5</b>                                                   | Echo Type 8 Traffic                                           |
| <b>Artifact 6</b>                                                   | ICMP Type 7 Traffic                                           |
| <b>Artifact 7</b>                                                   | SNMP Port 162 Traffic                                         |
| <b>Artifact 8</b>                                                   | SNMP Port 161 Traffic                                         |
| <b>Artifact 9</b>                                                   | Command Line Dialog Box Open                                  |
| <b>Artifact 10</b>                                                  | Operating System Queries                                      |
| <b>Artifact 11</b>                                                  | DNS Port 53 Zone Transfers                                    |
| <b>Artifact 12</b>                                                  | Industrial Network Traffic Content About Hostnames            |
| <b>Artifact 13</b>                                                  | Polling Network Traffic from Unauthorized IP Sender Addresses |
| <b>Artifact 14</b>                                                  | NETBIOS Name Services Port                                    |
| <b>Artifact 15</b>                                                  | LDAP Port                                                     |
| <b>Artifact 16</b>                                                  | Active Directory Calls                                        |
| <b>Artifact 17</b>                                                  | Email Server Calls                                            |
| <b>Artifact 18</b>                                                  | SMTP Port 25 Traffic                                          |
| <b>Artifact 19</b>                                                  | DNS Lookup Queries                                            |
| <b>Artifact 20</b>                                                  | ARP Scans                                                     |
| <b>Artifact 21</b>                                                  | TCP Connect Scan                                              |
| <b>Artifact 22</b>                                                  | TCP SYN Scans                                                 |
| <b>Artifact 23</b>                                                  | Scans Over Industrial Network Ports with Target IPS           |
| <b>Artifact 24</b>                                                  | TCP FIN Scans                                                 |

| Artifacts Associated with Remote System Discovery Technique (T0846) |                                                                   |
|---------------------------------------------------------------------|-------------------------------------------------------------------|
| <b>Artifact 25</b>                                                  | TCP Reverse Ident Scan                                            |
| <b>Artifact 26</b>                                                  | TCP XMAS Scan                                                     |
| <b>Artifact 27</b>                                                  | TCP ACK Scan                                                      |
| <b>Artifact 28</b>                                                  | VNC Port 5900 Calls                                               |
| <b>Artifact 29</b>                                                  | Protocol Content Enumeration                                      |
| <b>Artifact 30</b>                                                  | Protocol Header Enumeration                                       |
| <b>Artifact 31</b>                                                  | Recurring Protocol SYN Traffic                                    |
| <b>Artifact 32</b>                                                  | Sequential Protocol SYN Traffic                                   |
| <b>Artifact 33</b>                                                  | Statistical Anomalies in Network Traffic                          |
| <b>Artifact 34</b>                                                  | Industrial Network Traffic Content Containing Logical Identifiers |
| <b>Artifact 35</b>                                                  | Device Failure                                                    |
| <b>Artifact 36</b>                                                  | Device Reboot                                                     |
| <b>Artifact 37</b>                                                  | Bandwidth Degradation                                             |
| <b>Artifact 38</b>                                                  | Host Recent Connection Logs                                       |
| <b>Artifact 39</b>                                                  | Industrial Network Traffic                                        |
| <b>Artifact 40</b>                                                  | OPC Network Traffic                                               |
| <b>Artifact 41</b>                                                  | IEC 104                                                           |
| <b>Artifact 42</b>                                                  | IEC 102                                                           |
| <b>Artifact 43</b>                                                  | IEC 101 Traffic to Serial Devices                                 |

| Artifacts Associated with Remote System Information Discovery Technique (T0888) |                                                                                       |
|---------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| <b>Artifact 1</b>                                                               | Unexpected Industrial Protocol Usage                                                  |
| <b>Artifact 2</b>                                                               | Unexpected Industrial Application Usage                                               |
| <b>Artifact 3</b>                                                               | Unexpected Standard Protocol Usage                                                    |
| <b>Artifact 4</b>                                                               | Unexpected Recon Associated Command Line Options (Ping Sweep, netstat, etc.)          |
| <b>Artifact 5</b>                                                               | Unexpected Recon Associated Child Processes (Ping Sweep, netstat, etc.)               |
| <b>Artifact 6</b>                                                               | Unexpected Recon Associated Library Calls                                             |
| <b>Artifact 7</b>                                                               | Exfiltration of Host, Network, and/or System Architecture or Configuration Data       |
| <b>Artifact 8</b>                                                               | Compromise and Exfiltration of Data from Asset Information Datastores or Applications |

| Artifacts Associated with Point and Tag Identification Technique (T0861) |                            |
|--------------------------------------------------------------------------|----------------------------|
| <b>Artifact 1</b>                                                        | Industrial Network Traffic |

| Artifacts Associated with Point and Tag Identification Technique (T0861) |                                                                    |
|--------------------------------------------------------------------------|--------------------------------------------------------------------|
| <b>Artifact 2</b>                                                        | Control Server Logoff                                              |
| <b>Artifact 3</b>                                                        | Application Logs                                                   |
| <b>Artifact 4</b>                                                        | Application Manipulation                                           |
| <b>Artifact 5</b>                                                        | Application User Event                                             |
| <b>Artifact 6</b>                                                        | Application Reads                                                  |
| <b>Artifact 7</b>                                                        | Application Copy                                                   |
| <b>Artifact 8</b>                                                        | Point and Tag Data Exfiltration                                    |
| <b>Artifact 9</b>                                                        | Host System Registry Modification                                  |
| <b>Artifact 10</b>                                                       | User Registry Changes                                              |
| <b>Artifact 11</b>                                                       | Memory Location Changes                                            |
| <b>Artifact 12</b>                                                       | Common Network Traffic                                             |
| <b>Artifact 13</b>                                                       | OPC Requests                                                       |
| <b>Artifact 14</b>                                                       | .dll Creation                                                      |
| <b>Artifact 15</b>                                                       | .dll Execution                                                     |
| <b>Artifact 16</b>                                                       | .dll Hooking                                                       |
| <b>Artifact 17</b>                                                       | SQL Network Traffic                                                |
| <b>Artifact 18</b>                                                       | Database Vendor Specific Protocol Request                          |
| <b>Artifact 19</b>                                                       | Network Traffic Content Focused On Point and Tag Reads             |
| <b>Artifact 20</b>                                                       | External Point and Tag Read Requests Over Network Trust Boundaries |
| <b>Artifact 21</b>                                                       | Data Historian Reads                                               |
| <b>Artifact 22</b>                                                       | Data Historian Writes                                              |
| <b>Artifact 23</b>                                                       | Database Reads                                                     |
| <b>Artifact 24</b>                                                       | Control Server Reads                                               |
| <b>Artifact 25</b>                                                       | Data Historian Logon Event                                         |
| <b>Artifact 26</b>                                                       | Database Logon Event                                               |
| <b>Artifact 27</b>                                                       | Control Server Logon                                               |
| <b>Artifact 28</b>                                                       | DNS Queries Traffic Port                                           |
| <b>Artifact 29</b>                                                       | MAC Address                                                        |
| <b>Artifact 30</b>                                                       | Source IP Address                                                  |
| <b>Artifact 31</b>                                                       | Destination IP Address                                             |
| <b>Artifact 32</b>                                                       | Network Discover Protocols                                         |
| <b>Artifact 33</b>                                                       | SMB Port                                                           |
| <b>Artifact 34</b>                                                       | SNMP Port                                                          |
| <b>Artifact 35</b>                                                       | LLDP Requests                                                      |

| Artifacts Associated with Point and Tag Identification Technique (T0861) |                                         |
|--------------------------------------------------------------------------|-----------------------------------------|
| <b>Artifact 36</b>                                                       | HTTP Port                               |
| <b>Artifact 37</b>                                                       | Ping Echo Port                          |
| <b>Artifact 38</b>                                                       | Static Source IP Address                |
| <b>Artifact 39</b>                                                       | Usage of Default Account                |
| <b>Artifact 40</b>                                                       | Usage of Vendor Maintenance Account     |
| <b>Artifact 41</b>                                                       | Domain Name                             |
| <b>Artifact 42</b>                                                       | Domain Registrant Data                  |
| <b>Artifact 43</b>                                                       | Domain IP Resolution                    |
| <b>Artifact 44</b>                                                       | Domain Autonomous System Number         |
| <b>Artifact 45</b>                                                       | Hardware Serial Number Missing          |
| <b>Artifact 46</b>                                                       | Additional Hardware Inserted On Devices |
| <b>Artifact 47</b>                                                       | Mismatched Software Hashes              |
| <b>Artifact 48</b>                                                       | Device Failure                          |
| <b>Artifact 49</b>                                                       | Device Incompatibility Issues           |
| <b>Artifact 50</b>                                                       | Hardware Tampering Evidence             |
| <b>Artifact 51</b>                                                       | Hardware Failed Site Acceptance Test    |
| <b>Artifact 52</b>                                                       | Physical Defects to Hardware            |
| <b>Artifact 53</b>                                                       | Unscheduled Firmware Updates            |

| Artifacts Associated with Automated Collection Technique (T0802) |                              |
|------------------------------------------------------------------|------------------------------|
| <b>Artifact 1</b>                                                | Network Read Request         |
| <b>Artifact 2</b>                                                | OPC Read Requests            |
| <b>Artifact 3</b>                                                | Local Memory Read Requests   |
| <b>Artifact 4</b>                                                | Database Read Request        |
| <b>Artifact 5</b>                                                | POWERSHELL Command Arguments |
| <b>Artifact 6</b>                                                | User Account Logs            |
| <b>Artifact 7</b>                                                | SMB Traffic Port             |
| <b>Artifact 8</b>                                                | File Transfer                |
| <b>Artifact 9</b>                                                | Application Log              |
| <b>Artifact 10</b>                                               | Service Log                  |
| <b>Artifact 11</b>                                               | Native Tool Use              |
| <b>Artifact 12</b>                                               | External Network Connections |

| Artifacts Associated with Automated Collection Technique (T0802) |                               |
|------------------------------------------------------------------|-------------------------------|
| <b>Artifact 13</b>                                               | Command Line Arguments        |
| <b>Artifact 14</b>                                               | File Creation                 |
| <b>Artifact 15</b>                                               | File Execution                |
| <b>Artifact 16</b>                                               | Command Execution             |
| <b>Artifact 17</b>                                               | Internal Network Connections  |
| <b>Artifact 18</b>                                               | IP Addresses                  |
| <b>Artifact 19</b>                                               | MAC Addresses                 |
| <b>Artifact 20</b>                                               | Operational Data Exfiltration |
| <b>Artifact 21</b>                                               | User Account Creation         |
| <b>Artifact 22</b>                                               | User Account Privilege Change |
| <b>Artifact 23</b>                                               | SQL Read Requests             |

| Artifacts Associated with Commonly Used Port Technique (T0885) |                                                                            |
|----------------------------------------------------------------|----------------------------------------------------------------------------|
| <b>Artifact 1</b>                                              | Unexpected Process Usage of Common Port Observed via OS Commands (netstat) |
| <b>Artifact 2</b>                                              | Unexpected Process Usage of Common Port Observed via Memory                |
| <b>Artifact 3</b>                                              | Unexpected Process Usage of Common Port Observed via OS Logs               |
| <b>Artifact 4</b>                                              | Unexpected Process Usage of Common Port Observed via Firewall Logs         |
| <b>Artifact 5</b>                                              | Unexpected Host Communicating with Common Port on Industrial Asset         |

| Artifacts Associated with Standard Application Layer Protocol Technique (T0869) |                                                |
|---------------------------------------------------------------------------------|------------------------------------------------|
| <b>Artifact 1</b>                                                               | External Network Connections                   |
| <b>Artifact 2</b>                                                               | DNS Autonomous System Number                   |
| <b>Artifact 3</b>                                                               | Increase in the Number of External Connections |
| <b>Artifact 4</b>                                                               | Network Content Metadata                       |
| <b>Artifact 5</b>                                                               | Network Connection Times                       |
| <b>Artifact 6</b>                                                               | HTTP Traffic Port                              |
| <b>Artifact 7</b>                                                               | DNS Traffic Port                               |
| <b>Artifact 8</b>                                                               | SMB Traffic Port                               |
| <b>Artifact 9</b>                                                               | HTTPS Traffic Port                             |
| <b>Artifact 10</b>                                                              | RDP Traffic Port                               |
| <b>Artifact 11</b>                                                              | HTTP Post Request                              |
| <b>Artifact 12</b>                                                              | External IP Addresses                          |

| Artifacts Associated with Denial of Service Technique (T0814) |                                         |
|---------------------------------------------------------------|-----------------------------------------|
| <b>Artifact 1</b>                                             | Application Log                         |
| <b>Artifact 2</b>                                             | TDS Traffic Increase Port               |
| <b>Artifact 3</b>                                             | Increase Industrial Protocol Exceptions |
| <b>Artifact 4</b>                                             | Low Resources Warning                   |
| <b>Artifact 5</b>                                             | Ransom Notice                           |
| <b>Artifact 6</b>                                             | Services Failure                        |
| <b>Artifact 7</b>                                             | Network Traffic Connection Increase     |
| <b>Artifact 8</b>                                             | IP Addresses                            |
| <b>Artifact 9</b>                                             | MAC Addresses                           |
| <b>Artifact 10</b>                                            | External Network Connections            |
| <b>Artifact 11</b>                                            | Process Performance Degrades            |
| <b>Artifact 12</b>                                            | Operational Data Corruption             |
| <b>Artifact 13</b>                                            | Application Failure                     |
| <b>Artifact 14</b>                                            | ICMP Echo Port 7 Traffic Increase       |

| Artifacts Associated with Theft of Operational Information Technique (T0882) |                                                                                                                       |
|------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| <b>Artifact 1</b>                                                            | Exfiltration of Endpoint Host Data (Spreadsheets, Diagrams, Documents, Configurations, etc.) via Industrial Protocols |
| <b>Artifact 2</b>                                                            | Exfiltration of Endpoint Host Data (Spreadsheets, Diagrams, Documents, Configurations, etc.) via Standard Protocols   |
| <b>Artifact 3</b>                                                            | Exfiltration from Database via Standard Queries                                                                       |
| <b>Artifact 4</b>                                                            | Exfiltration of Operational Info via Phishing                                                                         |

| Artifacts Associated with Denial of Control Technique (T0813) |                                   |
|---------------------------------------------------------------|-----------------------------------|
| <b>Artifact 1</b>                                             | Input Failure                     |
| <b>Artifact 2</b>                                             | Increased Network Packet Delivery |
| <b>Artifact 3</b>                                             | Process Failure                   |
| <b>Artifact 4</b>                                             | Process Reboot                    |
| <b>Artifact 5</b>                                             | Serial Communication Failure      |
| <b>Artifact 6</b>                                             | Network Ports Opened              |
| <b>Artifact 7</b>                                             | Network Ports Closed              |
| <b>Artifact 8</b>                                             | Process Nonresponsive             |

## APPENDIX C: OBSERVERS

This is a collection of standardized potential observers that work in operational technology organizations. It has been slightly modified by the CyOTE team from the [Job Role Groupings listed in the SANS ICS Job Role to Competency Level Poster](#) to communicate the categories of potential observers during cyber events.

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Engineering</b>  <ul style="list-style-type: none"><li>• Process Engineer</li><li>• Electrical, Controls, and Mechanical Engineer</li><li>• Project Engineer</li><li>• Systems and Reliability Engineer</li><li>• OT Developer</li><li>• PLC Programmer</li><li>• Emergency Operations Manager</li><li>• Plant Networking</li><li>• Control/Instrumentation Specialist</li><li>• Protection and Controls</li><li>• Field Engineer</li><li>• System Integrator</li></ul> | <b>Support Staff</b>  <ul style="list-style-type: none"><li>• Remote Maintenance &amp; Technical Support</li><li>• Contractors (engineering)</li><li>• IT and Physical Security Contractor</li><li>• Procurement Specialist</li><li>• Legal</li><li>• Contracting Engineer</li><li>• Insurance</li><li>• Supply-chain Participant</li><li>• Inventory Management/Lifecycle Management</li><li>• Physical Security Specialist</li></ul> |
| <b>Operations Technology (OT) Staff</b>  <ul style="list-style-type: none"><li>• Operator</li><li>• Site Security POC</li><li>• Technical Specialists (electrical/mechanical/chemical)</li><li>• ICS/SCADA Programmer</li></ul>                                                                                                                                                                                                                                            | <b>Information Technology (IT) Cybersecurity</b>  <ul style="list-style-type: none"><li>• ICS Security Analyst</li><li>• Security Engineering and Architect</li><li>• Security Operations</li><li>• Security Response and Forensics</li><li>• Security Management (CSO)</li><li>• Audit Specialist</li></ul>                                                                                                                          |
| <b>Operational Technology (OT) Cybersecurity</b>  <ul style="list-style-type: none"><li>• OT Security</li><li>• ICS/SCADA Security</li></ul>                                                                                                                                                                                                                                                                                                                             | <ul style="list-style-type: none"><li>• Security Tester</li></ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| <b>Management</b>  <ul style="list-style-type: none"><li>• Plant Manager</li><li>• Risk/Safety Manager</li><li>• Business Unit Management</li><li>• C-level Management</li></ul>                                                                                                                                                                                                                                                                                         | <b>Information Technology (IT) Staff</b>  <ul style="list-style-type: none"><li>• Networking and Infrastructure</li><li>• Host Administrator</li><li>• Database Administrator</li><li>• Application Development</li><li>• ERP/MES Administrator</li><li>• IT Management</li></ul>                                                                                                                                                   |

## REFERENCES

- <sup>1</sup> [Symantec| "Dragonfly" | [https://docs.broadcom.com/doc/dragonfly\\_threat\\_against\\_western\\_energy\\_suppliers](https://docs.broadcom.com/doc/dragonfly_threat_against_western_energy_suppliers) | 7 July 2014 | Accessed on 21 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>2</sup> [Belden | Joel Langill | "Defending Against the Dragonfly Cyber Security Attacks" | [https://www.belden.com/hubfs/resources/knowledge/white-papers/Belden-White-Paper-Dragonfly-Cyber-Security-Attacks-AB\\_Original\\_68751.pdf?hsLang=en](https://www.belden.com/hubfs/resources/knowledge/white-papers/Belden-White-Paper-Dragonfly-Cyber-Security-Attacks-AB_Original_68751.pdf?hsLang=en) | 22 October 2014 | Accessed on 21 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>3</sup> [F-Secure Labs | "Havex Hunts for ICS/SCADA Systems" | <https://archive.f-secure.com/weblog/archives/00002718.html> | 23 June 2014 | Accessed on 21 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>4</sup> [Belden | Joel Langill | "Defending Against the Dragonfly Cyber Security Attacks" | [https://www.belden.com/hubfs/resources/knowledge/white-papers/Belden-White-Paper-Dragonfly-Cyber-Security-Attacks-AB\\_Original\\_68751.pdf?hsLang=en](https://www.belden.com/hubfs/resources/knowledge/white-papers/Belden-White-Paper-Dragonfly-Cyber-Security-Attacks-AB_Original_68751.pdf?hsLang=en) | 22 October 2014 | Accessed on 21 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>5</sup> [OPC Foundation | "What is OPC?" | <https://opcfoundation.org/about/what-is-opc/> | Accessed on 24 April 2022 | This source is publicly available and does not contain classified markings]
- <sup>6</sup> IBID
- <sup>7</sup> [Symantec| "Dragonfly" | [https://docs.broadcom.com/doc/dragonfly\\_threat\\_against\\_western\\_energy\\_suppliers](https://docs.broadcom.com/doc/dragonfly_threat_against_western_energy_suppliers) | 7 July 2014 | Accessed on 21 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>8</sup> [F-Secure Labs | "Havex Hunts for ICS/SCADA Systems" | <https://archive.f-secure.com/weblog/archives/00002718.html> | 23 June 2014 | Accessed on 21 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>9</sup> [Symantec| "Dragonfly" | [https://docs.broadcom.com/doc/dragonfly\\_threat\\_against\\_western\\_energy\\_suppliers](https://docs.broadcom.com/doc/dragonfly_threat_against_western_energy_suppliers) | 7 July 2014 | Accessed on 21 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>10</sup> [Belden | Joel Langill | "Defending Against the Dragonfly Cyber Security Attacks" | [https://www.belden.com/hubfs/resources/knowledge/white-papers/Belden-White-Paper-Dragonfly-Cyber-Security-Attacks-AB\\_Original\\_68751.pdf?hsLang=en](https://www.belden.com/hubfs/resources/knowledge/white-papers/Belden-White-Paper-Dragonfly-Cyber-Security-Attacks-AB_Original_68751.pdf?hsLang=en) | 22 October 2014 | Accessed on 21 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>11</sup> [F-Secure Labs | "Havex Hunts for ICS/SCADA Systems" | <https://archive.f-secure.com/weblog/archives/00002718.html> | 23 June 2014 | Accessed on 21 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>12</sup> [Belden | Joel Langill | "Defending Against the Dragonfly Cyber Security Attacks" | [https://www.belden.com/hubfs/resources/knowledge/white-papers/Belden-White-Paper-Dragonfly-Cyber-Security-Attacks-AB\\_Original\\_68751.pdf?hsLang=en](https://www.belden.com/hubfs/resources/knowledge/white-papers/Belden-White-Paper-Dragonfly-Cyber-Security-Attacks-AB_Original_68751.pdf?hsLang=en) | 22 October 2014 | Accessed on 21 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>13</sup> [Gigamon | Joe Slowik | "The Baffling Berserk Bear: A Decade's Activity Targeting Critical Infrastructure" | <https://vblocalhost.com/uploads/VB2021-Slowik.pdf> | 7 October 2021 | Accessed on 3 May 2022 | The source is publicly available information and does not contain classification markings]
- <sup>14</sup> [F-Secure Labs | "Havex Hunts for ICS/SCADA Systems" | <https://archive.f-secure.com/weblog/archives/00002718.html> | 23 June 2014 | Accessed on 21 March 2022 | The source is publicly available information and does not contain classification markings]
- <sup>15</sup> [Belden | Joel Langill | "Defending Against the Dragonfly Cyber Security Attacks" | [https://www.belden.com/hubfs/resources/knowledge/white-papers/Belden-White-Paper-Dragonfly-Cyber-Security-Attacks-AB\\_Original\\_68751.pdf?hsLang=en](https://www.belden.com/hubfs/resources/knowledge/white-papers/Belden-White-Paper-Dragonfly-Cyber-Security-Attacks-AB_Original_68751.pdf?hsLang=en) | 22 October 2014 | Accessed on 21 March 2022 | The source is publicly available information and does not contain classification markings]

Security-Attacks-AB\_Original\_68751.pdf?hsLang=en" | 22 October 2014 | Accessed on 21 March 2022 | The source is publicly available information and does not contain classification markings]

<sup>16</sup> [Gigamon | Joe Slowik | "The Baffling Berserk Bear: A Decade's Activity Targeting Critical Infrastructure" | <https://vblocalhost.com/uploads/VB2021-Slowik.pdf> / | 7 October 2021 | Accessed on 3 May 2022 | The source is publicly available information and does not contain classification markings]

<sup>17</sup> [FireEye | Kyle Wilhoit | "Havex, It's Down With OPC" | <https://www.fireeye.com/blog/threat-research/2014/07/havex-its-down-with-opc.html> | 17 July 2014 | Accessed on 2 April 2022 | The source is publicly available information and does not contain classification markings]

<sup>18</sup> [ACSAC | Rrushi & Others | "A Quantitative Evaluation of the Target Selection of Havex ICS Malware Plugin" | 2015 | Accessed on 21 March 2022 | The source is publicly available information and does not contain classification markings]

<sup>19</sup> [Hybrid Analysis | "7933809aecb1a9d2110a6fd8a18009f2d9c58b3c7dbda770251096d4fcc18849" | <https://www.hybrid-analysis.com/sample/7933809aecb1a9d2110a6fd8a18009f2d9c58b3c7dbda770251096d4fcc18849/5f86585c401535319c375515> | 14 October 2020 | Accessed on 25 April 2022 | This source is publicly available and does not contain classification markings]

<sup>20</sup> [Gigamon | Joe Slowik | "The Baffling Berserk Bear: A Decade's Activity Targeting Critical Infrastructure" | <https://vblocalhost.com/uploads/VB2021-Slowik.pdf> / | 7 October 2021 | Accessed on 3 May 2022 | The source is publicly available information and does not contain classification markings]

<sup>21</sup> [FireEye | Kyle Wilhoit | "Havex, It's Down With OPC" | <https://www.fireeye.com/blog/threat-research/2014/07/havex-its-down-with-opc.html> | 17 July 2014 | Accessed on 2 April 2022 | The source is publicly available information and does not contain classification markings]

<sup>22</sup> [ACSAC | Rrushi & Others | "A Quantitative Evaluation of the Target Selection of Havex ICS Malware Plugin" | 2015 | Accessed on 21 March 2022 | The source is publicly available information and does not contain classification markings]

<sup>23</sup> [FireEye | Kyle Wilhoit | "Havex, It's Down With OPC" | <https://www.fireeye.com/blog/threat-research/2014/07/havex-its-down-with-opc.html> | 17 July 2014 | Accessed on 2 April 2022 | The source is publicly available information and does not contain classification markings]

<sup>24</sup> IBID

<sup>25</sup> [S4 Events | Kyle Wilhoit | "ICS Malware: Havex and Black Energy" | <https://www.youtube.com/watch?v=eywmb7UDODY> | 7 August 2019 | Accessed on 20 April 2022 | Source is publicly available]

<sup>26</sup> IBID

<sup>27</sup> [Gigamon | Joe Slowik | "The Baffling Berserk Bear: A Decade's Activity Targeting Critical Infrastructure" | <https://vblocalhost.com/uploads/VB2021-Slowik.pdf> / | 7 October 2021 | Accessed on 3 May 2022 | The source is publicly available information and does not contain classification markings]

<sup>28</sup> [S4 Events | Corey Thuen | "Havex Deep Dive" | <https://www.youtube.com/watch?v=SyupAcnURtA> | 3 September 2017 | Accessed on 21 March 2022 | Sources is publicly available information and does not contain classification markings]

<sup>29</sup> [Belden | Joel Langill | "Defending Against the Dragonfly Cyber Security Attacks" | [https://www.belden.com/hubfs/resources/knowledge/white-papers/Belden-White-Paper-Dragonfly-Cyber-Security-Attacks-AB\\_Original\\_68751.pdf?hsLang=en](https://www.belden.com/hubfs/resources/knowledge/white-papers/Belden-White-Paper-Dragonfly-Cyber-Security-Attacks-AB_Original_68751.pdf?hsLang=en) | 22 October 2014 | Accessed on 21 March 2022 | The source is publicly available information and does not contain classification markings]

<sup>30</sup> [S4 Events | Corey Thuen | "Havex Deep Dive" | <https://www.youtube.com/watch?v=SyupAcnURtA> | 3 September 2017 | Accessed on 21 March 2022 | Sources is publicly available information and does not contain classification markings]

<sup>31</sup> [Cybersecurity Infrastructure Security Agency | "ICS Alert - 14-176-02A" | <https://www.cisa.gov/uscert/ics/alerts/ICS-ALERT-14-176-02A> | 27 June 2014 | Accessed 22 March 2022 | This source is publicly available and does not contain classification markings]

---

<sup>32</sup> [Cybersecurity Infrastructure Security Agency | "Alert AA22-083A" | <https://www.cisa.gov/uscert/ncas/alerts/aa22-083a> | 24 March 2022 | Accessed 25 March 2022 | This source is publicly available and does not contain classification markings]

<sup>33</sup> [Gigamon | Joe Slowik | "The Baffling Berserk Bear: A Decade's Activity Targeting Critical Infrastructure" | <https://vblocalhost.com/uploads/VB2021-Slowik.pdf> | 7 October 2021 | Accessed on 3 May 2022 | The source is publicly available information and does not contain classification markings]

<sup>34</sup> [S4 Events | Corey Thuen | "Havex Deep Dive" | <https://www.youtube.com/watch?v=SyupAcnURtA> | 3 September 2017 | Accessed on 21 March 2022 | Source is publicly available information and does not contain classification markings]

<sup>35</sup> [S4 Events | Kyle Wilhoit | "ICS Malware: Havex and Black Energy" | <https://www.youtube.com/watch?v=eywmb7UDODY> | 7 August 2019 | Accessed on 20 April 2022 | Source is publicly available]

<sup>36</sup> [Gigamon | Joe Slowik | "The Baffling Berserk Bear: A Decade's Activity Targeting Critical Infrastructure" | <https://vblocalhost.com/uploads/VB2021-Slowik.pdf> | 7 October 2021 | Accessed on 3 May 2022 | The source is publicly available information and does not contain classification markings]

<sup>37</sup> [Cybersecurity Infrastructure Security Agency | "ICS Alert - 14-176-02A" | <https://www.cisa.gov/uscert/ics/alerts/ICS-ALERT-14-176-02A> | 27 June 2014 | Accessed 22 March 2022 | This source is publicly available and does not contain classification markings]

<sup>38</sup> [Cybersecurity Infrastructure Security Agency | "Alert AA22-083A" | <https://www.cisa.gov/uscert/ncas/alerts/aa22-083a> | 24 March 2022 | Accessed 25 March 2022 | This source is publicly available and does not contain classification markings]